PCI-DSS DLP Pack — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — PCI-DSS DLP Pack (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 5

Boundaries (so scope is clear) . . . 5

1. Solution Overview — PCI-DSS DLP Pack (Microsoft Purview) 5

What this solution is . . . 5

Why this matters (PCI-DSS specifics) . . . 6

How it works . . . 6

The five DLP locations (and what each controls for card data) . . . 7

The simulate→enforce journey (the core discipline) . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 7

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 8

2. Requirements — PCI-DSS DLP Pack (Microsoft Purview) 9

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP and EDM . . . 9

2.2 DLP-specific least-privilege roles . . . 9

2.3 Devices onboarded to Purview for Endpoint DLP . . . 10

2.4 A card-data classification intent and the PAN detector inventory . . . 10

2.5 Source data for Exact Data Match (only if EDM is used for PAN) . . . 11

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific) . . . 11

2.7 A PAN-incident/alert triage owner and destination . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 14

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 14

3. Implementation Guide — PCI-DSS DLP Pack (Microsoft Purview) 15

Phase 0 — Connect and baseline (Assess) . . . 15

Phase 1 — Confirm the PAN detector (SITs & EDM) . . . 15

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact) . . . 16

Phase 3 — Measure and tune (drive false positives down) . . . 17
Phase 4 — Enforce in a pilot ring (Pilot) . . . 18
Phase 5 — Expand and harden (Enforce → Operate) . . . 18
Order-of-operations summary . . . 18
5. Testing & Validation — PCI-DSS DLP Pack (Microsoft Purview) 19
Test A — Detection & enforcement (PAN leaks are blocked) . . . 19
Test B — False-positive rate (adoption gate) . . . 20
Test C — Incident / alert handling (the control is operable) . . . 21
Simulation-first & rollback validation . . . 21
Evidence to capture (for the deliverable record / assessor) . . . 22
6. Troubleshooting — PCI-DSS DLP Pack (Microsoft Purview) 22
Policy / PAN detection . . . 22
Endpoint DLP . . . 23
False positives (the adoption killer) . . . 24
Alerts / incident handling . . . 24
Connectivity / tooling . . . 24
7. Best Practices — PCI-DSS DLP Pack (Microsoft Purview) 25
Simulate before you enforce — always . . . 25
Anchor on PAN, and tune for a low false-positive rate . . . 26
Respect the card-data rules (don't over- or under-reach) . . . 26
Right-size the user experience . . . 26
Endpoint DLP specifics . . . 27
Scoping and CDE hygiene . . . 27
Operations & governance . . . 27
Stay inside the boundary . . . 28
8. Deliverables Summary — PCI-DSS DLP Pack (Microsoft Purview) 28
Documentation . . . 28
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 29
Definition of done . . . 30
Appendix A — PowerShell Scripts 31

Executive Summary — PCI-DSS DLP Pack (Microsoft Purview)

The problem

Payment card numbers spread far beyond the systems built to hold them. A **Primary Account Number (PAN)** ends up in an email to a customer, pasted into a Teams chat, saved in a spreadsheet on OneDrive, copied to a USB stick, or printed from a laptop — every one a **cardholder-data exposure** and a **PCI-DSS gap** that also widens the scope an assessor has to examine. Left unaddressed, this "PAN sprawl" is invisible until it becomes an incident. The common failed attempt — switching a card-data control straight to "block" — halts legitimate payment workflows, floods the help desk with false positives, and gets turned off within a week.

The solution

Implement **Microsoft Purview Data Loss Prevention (DLP), tuned for cardholder data**, across all five locations — **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. Detection anchors on the built-in **Credit Card Number** sensitive information type (a card-brand pattern + **Luhn** checksum + supporting keywords), with **Exact Data Match** against your real PANs where near-zero false positives are required. The defining discipline is that **every policy is built and proven in SIMULATION first** — Microsoft's built-in test mode that shows what *would* be blocked, with zero user impact — then tuned for a **low false-positive rate**, then enforced to a **pilot ring**, then expanded. The result: card-data leaks are blocked without blocking the payment business.

What it delivers

- A confirmed **PAN detector** — the built-in Credit Card Number SIT (and optional EDM on your real PANs),

tuned to distinguish real card numbers from Luhn-valid internal reference numbers.

- **DLP policies across email, cloud, Teams, and endpoint**, each proven in simulation, tuned, and enforced

through policy tips, user justification/override, or block/encrypt.

- A **measured false-positive rate** kept at/under an agreed threshold — the difference between a control

people trust and one they ignore.

- A **PAN-incident/alert triage workflow** so every card-data match is investigated, with an evidence

trail in Activity Explorer and optional SIEM forwarding — the artifacts an assessor wants to see.

- **Five PowerShell tools** (posture assessment, policy config helper, endpoint-readiness checker,

match/false-positive report, scope helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **PAN leaks blocked** across the channels card data actually walks out through — email, cloud sharing, and USB/print on endpoints.

• **Minimal disruption** — simulation-first plus tuning means the control catches card-data exposure without a wave of false positives, and any policy reverts to simulation instantly if needed.

• **Operable and auditable** — matches raise alerts that are triaged to disposition, with evidence retained for the assessor.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and tooled to run in-house.

Boundaries (so scope is clear)

DLP is licensing-/plan-dependent — **Endpoint DLP and EDM require E5 / E5 Compliance and onboarded devices** (verify your tenant). This solution provides the **technical configuration and the evidence**; the **CDE boundary and PCI scope**, *which* card-data flows are in scope, the **enforced action per flow**, the **acceptable false-positive threshold**, and **PCI-DSS compliance/attestation** are **compliance, PCI, and QSA determinations**, captured alongside the delivered evidence. This solution does not attest to PCI-DSS compliance.

1. Solution Overview — PCI-DSS DLP Pack (Microsoft Purview)

What this solution is

Payment card numbers spread far beyond the systems that are supposed to hold them. A **Primary Account Number (PAN)** ends up in an email to a customer, pasted into a Teams chat, saved in a spreadsheet on OneDrive, copied to a USB stick, or printed from a laptop — every one of those a **cardholder-data exposure** and a **PCI-DSS gap**. This solution uses **Microsoft Purview Data Loss Prevention (DLP)**, tuned specifically for **cardholder data**, to detect and control that movement: it matches content against the **Credit Card Number** sensitive information type (a Luhn-validated PAN detector) and related classifiers, then applies a policy action — **audit**, warn with a **policy tip**, allow with a business **justification**, or **block** — across **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)**.

It is a repeatable, evidence-driven way to stand up PCI-aligned DLP using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling. Its defining discipline is that **every policy is built and proven in SIMULATION mode first** (Microsoft's built-in test mode that evaluates policy against real traffic and shows what *would* have matched, without affecting a single user), tuned for a **low false-positive rate**, and only then moved to enforcement — because a card-data DLP policy switched straight to *block* halts legitimate payment workflows and gets turned off within a week.

> ***Scope boundary.*** *This solution delivers the* ***technical method and evidence*** *for detecting and controlling cardholder data. *Which* systems are inside your* ***Cardholder Data Environment (CDE)****,*

what your PCI-DSS scope is, *whether* a given data flow is compliant, and *what* the enforced action must be are ***PCI, compliance, and QSA (Qualified Security Assessor) determinations*** — deferred to those functions. The solution helps you configure and prove the control and produce evidence for an assessor; it does not make the compliance determination or attest to PCI-DSS compliance.

Why this matters (PCI-DSS specifics)

- **PCI-DSS is about where PAN lives and moves.** DLP tuned for cardholder data directly supports the standard's account-data-protection and scoping objectives by **finding PAN outside the CDE** (email, files, chat, endpoints) — the "PAN sprawl" that widens assessment scope and creates exposure.
- **Sensitive Authentication Data (SAD) must never be stored.** PCI-DSS prohibits storing full track data, card verification codes (CVV/CVV2/CVC2/CID), and PINs after authorization. DLP helps you *detect* SAD-in-storage as an early-warning signal — but SAD detectors are weak on their own (a 3–4 digit code is not reliably distinguishable), so this solution anchors on **PAN detection** and treats SAD as a keyword-supported, best-effort signal, not a guarantee.
- **False positives are the enemy of adoption.** The built-in Credit Card detector will fire on any Luhn-valid 13–19 digit sequence — including internal reference numbers. Tuning (confidence, instance count, supporting keywords, and **Exact Data Match** against your real PANs) is what makes the control trusted by the business.
- **Evidence is the deliverable an assessor wants.** DLP match reports, Activity Explorer trails, and a documented simulate→enforce change log are the artifacts that demonstrate the control operates — the evidence a QSA reviews (the compliance *determination* stays with the QSA).

How it works

1. **Sensitive information types (SITs) for cardholder data.** The built-in **Credit Card Number** SIT detects PANs via a **card-brand pattern + Luhn checksum + supporting keywords** across the major brands (Visa, Mastercard, Amex, Discover, JCB, Diners). Where you need near-zero false positives on *your* card numbers, add an **Exact Data Match (EDM)** SIT built from a hashed upload of your PAN table.
1. **DLP policies** bind those SITs to **locations** (Exchange, SharePoint, OneDrive, Teams chat/channel, and **Devices/Endpoint**) with **conditions** (which SIT, how many instances, what confidence), **actions** (audit / notify / restrict / block, restrict USB/print/cloud-upload on endpoint), and **user experience** (policy tips, allow-with-justification, allow-override).
1. **Simulation mode** runs each policy against live traffic and records what *would* have matched — with or without policy tips shown — so you see true PAN hit volume and false positives **before** any enforcement. Every policy in this solution starts here.
1. **Tuning** reduces false positives using confidence levels, instance thresholds, supporting keyword evidence, EDM, and exceptions — measured against the simulation results.
1. **Enforcement** turns the tuned policy on (tips/override/block) in a limited ring, then expands.

2. **Incident/alert handling** — DLP rule matches raise **alerts** in the Purview portal and DLP events flow to **Activity Explorer**; this solution wires the triage, severity, and response workflow so PAN matches are actually investigated and dispositioned.

The five DLP locations (and what each controls for card data)

- **Exchange (email):** outbound/inbound mail containing PAN in the body or attachments; block or encrypt on match — the most common way a card number walks out.
- **SharePoint & OneDrive:** documents at rest and when shared; block external sharing of files containing PAN — the "spreadsheet of card numbers shared anyone-with-the-link" case.
- **Teams chat & channel messages:** PAN pasted or shared in messages.
- **Endpoint (Devices):** activities on **onboarded** Windows/macOS devices — copy PAN-bearing files to USB, copy to network share, print, upload to unallowed cloud apps/browsers, copy to clipboard, paste to browser. **Requires onboarding and the right licensing.**
- **On-premises / cloud apps (Defender for Cloud Apps):** additional locations that may be available depending on licensing — **verify availability in your tenant.**

The simulate→enforce journey (the core discipline)

> *Confirm the PAN SIT (and optional EDM) → build each DLP policy in **SIMULATION** (no user impact) → measure PAN hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** (confidence, instance count, keywords, EDM, exceptions) → re-simulate until false positives are acceptable → enable with **policy tips + allow-override/justification** in a **pilot ring** → validate → expand to **enforce (block)** for the intended scope → operate (triage PAN alerts, review overrides, re-tune).*

What you can control

- Which SITs/classifiers detect card data and at what **confidence** and **instance count** they trigger (e.g. a single PAN vs a bulk export of ≥10).
- Which **locations** each policy covers and which users/sites/groups are **included or excluded** (e.g. scope out the sanctioned in-CDE payment application, scope in everything else).
- The **action** per flow (audit → tip → justify → block) — set per the PCI/compliance determination.
- Whether users get **policy tips**, can **override** with justification, and what the override says.
- The **pilot ring** enforced first, and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

- **Endpoint DLP requires onboarded devices and the appropriate licensing** (verify your plan — endpoint

DLP, EDM, and several advanced classifiers are gated behind E5 / the E5 Compliance add-on). A Devices-location policy is inert until onboarding is complete.

• **PAN detection is content-based.** DLP inspects content it can classify; strongly encrypted files, images of cards, unrecognized formats, or a PAN split across fields may not match. **Truncated PANs** (first six/last four, per PCI display rules) are intentionally *not* full PANs and will not — and should not — match a full-PAN detector. DLP is one control among several, not proof the CDE is contained.

• **SAD detection is best-effort.** CVV/track/PIN detectors are weak in isolation; treat SAD hits as a signal to investigate, not a reliable control.

• **EDM is what drives false positives toward zero** but requires the schema, a hashed upload, and an ongoing refresh — it is not zero-effort.

• **Some features are in preview** and portal paths **evolve** — this solution flags "verify your licensing/tenant" rather than asserting availability that may differ in your tenant.

• **PCI scope, CDE boundaries, the enforced action per flow, and compliance/QSA sign-off are determinations for your compliance function and assessor** — this solution configures and proves the control and produces the evidence; it does not attest to compliance.

Naming convention (used in every doc and script)

Every artifact this solution creates uses a consistent name, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
PAN detector (built-in SIT)	`Credit Card Number` (built-in — do not recreate)
EDM schema / SIT (your real PANs)	`Cardholder PAN – EDM – PCI`
Email DLP policy (simulation)	`DLP – Email PAN – Simulation`
Cloud DLP policy (simulation)	`DLP – SPO+OneDrive+Teams PAN – Simulation`
Endpoint DLP policy (simulation)	`DLP – Endpoint PAN – Simulation`
Enforced pilot policy	`DLP – All Locations PAN – Enforce Pilot`
Pilot user ring	`PCI DLP Pilot Ring – Stage1`
Policy-tip / override text	`PCI DLP Notice – Standard – AllPolicies`
Incident/alert workflow	`PCI DLP Alerts – Triage – Operations`

The standard deployment model

> ***Assess*** *current PAN exposure (where card data lives today) →* ***Design*** *the PAN SIT / EDM and the policies + user experience →* ***Configure*** *SITs and policies* ***in simulation*** *→* ***Pilot*** *(simulate → tune → enforce to a ring) →* ***Validate*** *against pass/fail gates (PAN leaks blocked, false-positive rate low, incidents handled) →* ***Expand*** *to the intended enforcement scope and ongoing operations. Every high-impact change is piloted in simulation first, with a documented rollback.*

2. Requirements — PCI-DSS DLP Pack (Microsoft Purview)

These are the **solution-specific** prerequisites for implementing cardholder-data DLP across endpoint, cloud, and email. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP and EDM

• **Description:** DLP for **Exchange/SharePoint/OneDrive/Teams** using the **built-in Credit Card Number

SIT **is broadly available, but** Endpoint DLP**,** Exact Data Match (EDM)**, and** trainable classifiers **are** plan-gated **— typically** Microsoft 365 E5 **or the** E5 Compliance **add-on (some capabilities are in** preview**). This extends GR-#1 with the DLP-specific plan detail.

• **Why required:** A DLP policy scoped to a location or using a classifier your plan doesn't include will

not function. Endpoint DLP and EDM in particular are E5/E5-Compliance capabilities — and EDM is the tool that drives PAN false positives toward zero.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the

Purview portal → **Data Loss Prevention** confirm the **Endpoint DLP** / **Devices** location and, under **Data classification** → **Exact data matches**, that EDM is available. **Flag "verify your licensing/tenant"** — availability evolves.

• **How to implement if missing:** Acquire/assign the required licensing (E5 or E5 Compliance) before

building endpoint or EDM policies; scope the initial rollout to features your plan covers (the built-in Credit Card SIT across email/cloud works on broadly-available plans).

2.2 DLP-specific least-privilege roles

• **Description:** The **DLP role groups** in the Purview portal — **Compliance Administrator** or

Compliance Data Administrator to create/manage DLP policies, **DLP Compliance Management** for policy management, **View-Only DLP Compliance Management** for read-only review, and the **Data Loss Prevention** role for alert/incident handling. Global Administrator only where genuinely required. Extends GR-#2.

• **Why required:** Purview enforces fine-grained role groups; DLP configuration and alert triage require

the matching role, and least privilege keeps the blast radius small. PCI environments in particular expect documented role separation.

• **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (or Microsoft Purview

roles) — confirm your account's role-group membership includes the DLP roles you need.

• **How to implement if missing:** Assign the least-privilege DLP role group under change control; separate

policy authors from alert triagers where possible.

2.3 Devices onboarded to Purview for Endpoint DLP

• **Description:** Endpoint DLP monitors PAN-related activities on **onboarded Windows 10/11 and macOS

devices **— copy to USB, print, upload to unallowed cloud apps, clipboard/paste. Onboarding is done in** Purview portal → Settings → Device onboarding **(or via Intune / a script / Group Policy), and is** shared with Microsoft Defender for Endpoint onboarding**.

• **Why required:** A DLP policy scoped to the **Devices** location does nothing on a device that is not

onboarded and reporting — and endpoints are a primary path for card-data exfiltration (a spreadsheet of PANs to a USB stick).

• **How to verify: Purview portal** → **Settings** → **Device onboarding** → **Devices** shows onboarded devices;

confirm target devices appear and are reporting. Script #3 provides a licensing/onboarding signal.

• **How to implement if missing:** Onboard devices via the Purview device-onboarding package, Intune, or

Group Policy; confirm the minimum OS build and required AV/agent state per Microsoft docs before scoping endpoint policies.

2.4 A card-data classification intent and the PAN detector inventory

• **Description:** A documented view of **what cardholder data you are protecting** (full PAN as the

primary target; cardholder name / expiry / service code as cardholder data; CVV/track/PIN as Sensitive Authentication Data that must not be stored) mapped to the **SITs/classifiers** that detect it — the built-in **Credit Card Number** SIT for PAN, plus **EDM** for your real PANs where near-zero false positives are required. Extends GR-#4.

• **Why required:** DLP policies key off SITs; card-data DLP anchors on the PAN detector. Without knowing

which card brands and instance counts matter, policies are guesswork and generate false positives.

• **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** —

confirm the built-in **Credit Card Number** SIT exists and review its confidence levels and default instance count (Discovery script #1 reports coverage).

• **How to implement if missing:** Confirm the built-in PAN SIT; plan an EDM schema for your real card

numbers if pattern matching over-fires; document which card brands and thresholds are in scope with the data owners. *Which flows are in PCI scope is the compliance/QSA determination.*

2.5 Source data for Exact Data Match (only if EDM is used for PAN)

• **Description:** For an **EDM** PAN SIT, a **sensitive data table** (an export of your real PANs — handled under strict access control) and a workstation with the **EDM Upload Agent** to hash and upload it — the raw PANs never leave your control; only salted hashes are uploaded.

• **Why required:** EDM matches against *your actual PANs*, which drives false positives toward zero — but it requires the schema, the hashed upload, and a **refresh cadence** as the card data changes. Handling the source table is itself a card-data-security activity.

• **How to verify:** Confirm the source table, the EDM schema (`Cardholder PAN – EDM – PCI`), the upload agent host, and a scheduled refresh. **Purview portal** → **Data classification** → **Exact data matches** shows configured EDM schemas.

• **How to implement if missing:** Define the EDM schema and refresh process under card-data handling controls (deferred to the data owner for *which* fields are in scope); if EDM is not in your plan or not needed, use the built-in Credit Card SIT with confidence/instance/keyword tuning instead.

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific)

• **Description:** A named **pilot user/device ring** (`PCI DLP Pilot Ring – Stage1`), an agreed **simulation dwell time** (how long each policy runs in simulation before enforcement — long enough to capture representative card-data traffic), and the **change-control window** for moving simulation → enforce. Extends GR-#6.

• **Why required:** Card-data DLP is high-impact; enforcing without a simulation baseline and a limited ring is how DLP breaks legitimate payment/finance workflows. The house model mandates **simulation first**, then a ring, then expand.

• **How to verify:** Confirm the pilot ring membership, that **simulation mode** is selected on each new policy, and the approval path to enforce.

• **How to implement if missing:** Define the ring and dwell time and agree change control before enabling any enforcement action.

2.7 A PAN-incident/alert triage owner and destination

• **Description:** A named owner (or queue) for **DLP alerts** raised in **Purview portal → Data loss

prevention → Alerts **(**`PCI DLP Alerts – Triage – Operations`**), plus where DLP events are reviewed (**Activity Explorer**) and, optionally, forwarded (SIEM/Microsoft Sentinel via the Office 365 Management Activity API / Defender connectors). Severity and response actions defined — a PAN match is a cardholder-data exposure that may require its own handling per your incident-response plan.

• **Why required:** A PAN match with no one to triage it is not a control. Alerts and Activity Explorer are where matches surface; someone must own triage, severity, and response — and PCI expects a defined incident-response process for cardholder-data events.

• **How to verify:** Confirm the triage owner/queue, the alert-severity scheme, and any SIEM forwarding is configured.

• **How to implement if missing:** Assign the owner, define severity/response (aligned to your incident-response plan), and (optionally) wire SIEM forwarding before enforcement generates real alerts.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	DLP/Endpoint/EDM licensing (E5 / E5 Compliance; verify)	Endpoint, EDM & advanced classifiers available
2.2	DLP least-privilege roles	Author + triage roles assigned
2.3	Devices onboarded to Purview	Endpoint location functional
2.4	Card-data classification intent + PAN detector inventory	Policies key off the Credit Card SIT (+EDM)
2.5	EDM source PAN table + agent (if used)	Near-zero-FP PAN matching where needed
2.6	Pilot ring + simulation dwell + change control	Simulate-first enforced
2.7	PAN alert/incident triage owner + destination	Card-data matches are acted on

> ***Deferred to compliance/PCI/QSA:*** *the CDE boundary and PCI scope, which flows are in scope, the enforced action per flow, and compliance sign-off/attestation. This solution provides the technical configuration and evidence, not the determination or attestation.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication

compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant

governance functions.*

3. Implementation Guide — PCI-DSS DLP Pack (Microsoft Purview)

This is the exact, ordered procedure to implement cardholder-data DLP across **email, cloud, Teams, and endpoint** — every policy built in **SIMULATION** first, tuned, then enforced in a ring, then expanded. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`) and* ***Microsoft Graph****. They are* ***read-only or*** `-WhatIf` ***by default****; writes require an explicit* `-Commit` *switch. No credentials are stored in code.*
>
> ***Determinations deferred.*** *The* ***CDE boundary and PCI scope****, *which* card-data flows are in scope, and the *enforced action* per flow are* ***compliance/PCI/QSA*** *decisions. This guide configures and proves the control and produces evidence; capture those decisions before Phase 4 (enforcement).*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\PURVPCI-Discovery.ps1 -CsvPath .\PURVPCI-Posture.csv
```

It reports existing DLP policies and their mode, confirms the built-in **Credit Card Number** SIT and any EDM schemas, and surfaces licensing/endpoint readiness signals.

1. **Confirm licensing and endpoint readiness** (Req 2.1, 2.3): confirm E5/E5-Compliance where endpoint or

EDM are needed, and that target devices are **onboarded** (script #3 checks this).

Pass/fail gate: you have a written baseline (existing policies + modes), confirmation that the Credit Card Number SIT is present, and confirmed licensing + endpoint onboarding for the locations you will target. **Rollback:** none (read-only).

Phase 1 — Confirm the PAN detector (SITs & EDM)

Anchor detection on the built-in PAN SIT; add EDM only where near-zero false positives on *your* card numbers are required. Do **not** invent SITs.

1. **Confirm the built-in Credit Card Number SIT.** In **Purview portal → Data classification →

Classifiers → Sensitive info types**, open** Credit Card Number **and review its** confidence levels **(it combines a card-brand pattern, the** Luhn checksum**, and supporting keywords such as card-brand names and "credit card") and its default** instance count**. This one SIT covers the major brands (Visa, Mastercard, Amex, Discover, JCB, Diners) — do not recreate it.

1. **(Optional) Configure EDM for your real PANs** (Req 2.5) where pattern matching over-fires. Define the

schema `Cardholder PAN – EDM – PCI`, hash-and-upload the source PAN table with the **EDM Upload Agent** under card-data handling controls, and set a **refresh cadence**. Portal: **Data classification** → **Exact data matches**. *Which fields are in scope is the data owner's determination.*

1. **(Optional) Add SAD signals with caution.** If you want an early-warning signal for **Sensitive

Authentication Data **(track data, CVV) in storage, pair the PAN SIT with** supporting keywords** (e.g. "CVV", "CVC", "track data") rather than relying on a standalone 3–4-digit detector — and treat any SAD hit as *investigate*, not *proven violation*.

Pass/fail gate: the Credit Card Number SIT is confirmed at a chosen confidence and instance count, and (if used) the EDM schema is uploaded and shows as configured. **Rollback:** delete unused EDM schemas (they have no effect until referenced by a policy); the built-in SIT is unchanged.

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact)

Create **one policy per location group**, each in **simulation mode**. Simulation evaluates the policy against real traffic and records what *would* match, with **no** enforcement and (optionally) with policy tips shown.

1. **Email DLP policy —** `DLP – Email PAN – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → use the **PCI-DSS** category template or a custom policy → **Locations: Exchange email only** → rule: condition *Content contains* the **Credit Card Number** SIT (and `Cardholder PAN – EDM – PCI` if used) at the chosen confidence/instance count → action *Restrict access or encrypt* (kept inert by simulation) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Finish.

1. **Cloud DLP policy —** `DLP – SPO+OneDrive+Teams PAN – Simulation`**.**

Same flow → **Locations: SharePoint sites, OneDrive accounts, Teams chat and channel messages** → condition *Content contains* Credit Card Number → action *Restrict access* (block external sharing on match) → **simulation mode**.

1. **Endpoint DLP policy —** `DLP – Endpoint PAN – Simulation` (requires onboarded devices + licensing).

Same flow → **Locations: Devices** → condition *Content contains* Credit Card Number → **endpoint activities to audit/restrict**: *copy to USB/removable media*, *copy to network share*, *print*, *upload to unallowed cloud apps/browser*, *copy to clipboard*, *paste to browser* → **simulation mode**. Confirm the Devices location is selectable (if not, revisit licensing/onboarding — Req 2.1/2.3).

1. **Set the user experience** consistently: define `PCI DLP Notice – Standard – AllPolicies` policy-tip

text (business language: *"This looks like a payment card number. Sending it this way may violate PCI policy — remove it or use the approved process."*) and enable **allow override with justification** where compliance permits — but note tips/overrides only *appear* once a policy is enforced; in simulation they are captured, not shown to end users unless "simulation with policy tips" is selected.

1. **Verify with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\PURVPCI-Config.ps1 -PolicyName 'DLP - Email PAN - Simulation' -Locations Exchange `
    -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -WhatIf
```

Run with `-Commit` only to apply an intended change; the script never leaves a policy in enforce mode.

Pass/fail gate: all three policies exist and are confirmed in **simulation** (script #1/#2 report `Mode = TestWithNotifications / TestWithoutNotifications`), scoped to the correct locations and the Credit Card Number SIT. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.6) to capture representative card-data traffic.

1. **Review what matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities) show every simulated match with the file/message, the SIT, and the confidence. Export with the reporting script:

```
.\PURVPCI-Report.ps1 -Days 14 -CsvPath .\PURVPCI-Matches.csv
```

1. **Classify each match** as true positive (real PAN) or **false positive** and identify the false-

positive drivers — the classic being the Credit Card SIT firing on a Luhn-valid **internal reference or order number**.

1. **Tune** to reduce false positives without losing true positives:

• Raise the **confidence level** so only high-confidence (keyword-supported) PAN matches count.

• Raise the **instance count** for a bulk-leak focus (e.g. require ≥10 PANs to flag a spreadsheet

export) — but keep a **single-PAN** policy where a lone card number in an email is the concern.

• Introduce **EDM** (`Cardholder PAN – EDM – PCI`) for storage where the built-in pattern over-matches.

• Add **exceptions** (e.g. exclude the sanctioned in-CDE payment application's mailbox/site) where

justified and documented.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets the

validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with real PANs still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the diff before `-Commit`).

Phase 4 — Enforce in a pilot ring (Pilot)

1. **Scope to the pilot ring.** Add `PCI DLP Pilot Ring – Stage1` (users) and pilot devices as the

included scope on each policy (all other users/devices excluded for now) — script #5 helps set the member-of scope.

1. **Move the ring to enforcement.** Change **Policy mode** from *simulation* to **Turn it on / Enforce**.

Start with **policy tips + allow-override (justification)** rather than hard block, so the pilot can report false negatives/positives while retaining a business escape hatch for legitimate card-handling workflows.

1. **Confirm enforcement is live** for the ring only (script #1 reports mode `Enable` and the scoped

identities). Confirm ring users now see the `PCI DLP Notice – Standard – AllPolicies` tip on a test match with a **fake** test PAN.

1. **Handle incidents.** Wire `PCI DLP Alerts – Triage – Operations`: assign the alert owner/queue

(Req 2.7), set severities aligned to your incident-response plan, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot PAN alert end-to-end to prove the workflow.

Pass/fail gate: the pilot ring is enforced (tips shown, overrides captured), PAN matches raise alerts, and the triage workflow produces a dispositioned incident. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand and harden (Enforce → Operate)

1. **Expand scope** from the ring to the full intended population once the pilot gate passes, keeping

documented exclusions (e.g. the sanctioned in-CDE application).

1. **Escalate the action** per compliance's determination — e.g. move email PAN from *tip + override* to

block/encrypt where required — one flow/location at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review

user overrides (are people justifying legitimately or routinely bypassing?), refresh **EDM** data on cadence, and re-tune as data and behavior change.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail

evidence for the assessor.

Pass/fail gate: enforcement live across the intended scope with the compliance-mandated action per flow; false-positive rate steady/low; alerts triaged on cadence; overrides reviewed; evidence captured.
Rollback: any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; individual policies can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, confirm licensing/onboarding + PAN SIT	Posture CSV	Baseline + readiness confirmed	n/a (read-only)
1 Detector	Confirm Credit Card SIT; optional EDM	`Cardholder PAN – EDM – PCI`	PAN detector confirmed/tested	Delete unused EDM
2 Configure	Build 3 policies in **simulation**	Email/Cloud/Endpoint PAN sim policies	All in simulation, correct scope	Delete sim policy
3 Tune	Measure + reduce false positives	Matches CSV	FP rate ≤ threshold, PANs still caught	Revert tuning change
4 Pilot	Enforce to ring, wire alerts	Pilot ring, alert triage	Ring enforced, PAN incident dispositioned	Back to simulation
5 Expand	Broaden scope, escalate to block, operate	Enforced policies	Full-scope enforce, low FP, alerts triaged	Simulation / disable

5. Testing & Validation — PCI-DSS DLP Pack (Microsoft Purview)

Validate the cardholder-data DLP implementation against explicit **pass/fail gates**. The three headline gates for this solution are: **(A) PAN leaks are blocked**, **(B) the false-positive rate is low**, and **(C) incidents are handled**. Run every test with **non-real, clearly-fake test PANs** — use the standard documented test card numbers (e.g. Visa test PAN `4111 1111 1111 1111`, or `4242 4242 4242 4242`) — and **never real cardholder data**. Record the evidence.

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the **pilot ring**. Endpoint tests require an **onboarded** device (Req 2.3). Test PANs are Luhn-valid but not issued to any account, so they exercise the detector without handling real card data.*

Test A — Detection & enforcement (PAN leaks are blocked)

#	Test	Steps	Pass condition
A1	Email PAN blocked	From a pilot-ring user, send an email to an **external** recipient containing a fake test PAN (enough instances to meet the threshold).	Message is blocked/encrypted per the enforced action; sender sees the policy tip; a DLP alert is raised.

#	Test	Steps	Pass condition
A2	SharePoint/OneDrive external share blocked	As a ring user, upload a file containing a fake test PAN and attempt to share it **externally**.	External sharing is blocked/restricted on match; event appears in Activity Explorer.
A3	Teams PAN message	Paste a fake test PAN into a Teams chat/channel covered by the policy.	Message is blocked or tipped per the enforced action; event logged.
A4	Endpoint — USB copy	On an onboarded ring device, copy a file containing a fake test PAN to **removable media**.	Activity is audited/blocked per policy; endpoint DLP event appears in Activity Explorer.
A5	Endpoint — print / cloud upload	On the ring device, attempt to **print** the PAN file and **upload** it to an unallowed cloud app/browser.	Each activity is audited/restricted per policy; events logged.
A6	Truncated-PAN / below-threshold negative	Send a **truncated** PAN (first-six/last-four per PCI display rules) or fewer PAN instances than the threshold.	Correctly **not** matched — confirms truncated PANs and threshold tuning don't over-fire.

Gate A (pass): A1–A5 each produce the enforced action and a logged event; A6 correctly does not match.

Test B — False-positive rate (adoption gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time, export simulation matches (`PURVPCI-Report.ps1 -Days <n>`) and classify each as TP (real PAN) / FP.	**False-positive rate** ≤ **the agreed threshold** (define with compliance; a common target is ≤10% of matches, or an absolute FP count the triage team can absorb).
B2	Internal-reference-number negative	Run representative legitimate business content containing **Luhn-valid internal reference/order numbers** (no real card data) through the covered channels.	Internal numbers are **not** matched as PAN — no spurious tips/blocks.

#	Test	Steps	Pass condition
B3	Post-tuning re-measure	After each tuning change (confidence↑, instance count↑, keywords, EDM, exceptions), re-simulate and re-measure.	FP rate trends **down** while true PAN positives (Test A) still fire.
B4	Override sanity	In the pilot ring, review captured **allow-with-justification** overrides.	Overrides are legitimate business justifications, not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with real-PAN detection intact.

Test C — Incident / alert handling (the control is operable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a PAN match (Test A1/A4).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.
C2	Triage workflow	The `PCI DLP Alerts – Triage – Operations` owner/queue picks up the alert, sets status, and dispositions it per the incident-response plan.	Alert moves through the defined states to a resolved disposition by the named owner.
C3	Activity Explorer trail	Locate the same event in **Data classification** → **Activity explorer**.	Full evidence trail present (user, location, SIT, action) for investigation and assessor evidence.
C4	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.7).	Event present in the downstream system with usable fields.

Gate C (pass): PAN matches raise alerts, alerts are triaged to disposition by the owner, and the evidence trail (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `PCI DLP Pilot Ring – Stage1` experience no blocking during pilot.
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-blocked PAN action now only simulates).
S3	Scripts are safe-by-default	`PURVPCI-Config.ps1` / `PURVPCI-Set-Scope.ps1` run **without** `-Commit` make no change (`-WhatIf` output only); discovery/report/endpoint-check scripts are read-only.

Evidence to capture (for the deliverable record / assessor)

• Baseline posture CSV (Phase 0) and confirmation the Credit Card Number SIT is present.

• Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).

• Screenshots/log of Test A enforcement actions on **fake test PANs** and the raised alerts (Gate A/C).

• The dispositioned incident from Test C2 and, if used, the SIEM forward (C4).

• Confirmation that outside-ring users were unaffected (S1) and that simulation rollback works (S2).

• The change log of each simulate→enforce transition with the compliance sign-off attached.

Determination boundary. *These tests prove the **control works** and produce evidence. Whether the enforced action, the FP threshold, and the CDE scope are *acceptable for PCI-DSS* is a compliance/QSA sign-off, captured alongside the evidence above — this solution does not attest to compliance.*

6. Troubleshooting — PCI-DSS DLP Pack (Microsoft Purview)

Symptom-first fixes for the failures you actually hit implementing cardholder-data DLP across email, cloud, Teams, and endpoint. Most problems are one of: a PAN policy not matching, the endpoint location unavailable, too many false positives (Luhn-valid internal numbers), or matches that raise no alert.

Policy / PAN detection

A PAN DLP policy matches nothing even though the content clearly contains a card number.

• Confirm the policy is actually **enabled and in a mode that evaluates** — a *disabled* policy does

nothing; a **simulation** policy evaluates and logs but does not block. Check with `PURVPCI-Discovery.ps1` (Mode column).

- Check the **instance count and confidence** on the rule — if it requires ≥10 PANs at High confidence and

your test has 1, it correctly won't fire. Use the **single-PAN** policy (MinCount 1) for lone-card tests, or add more fake test PANs.

- **Use a Luhn-valid test PAN.** The built-in Credit Card Number SIT enforces the **Luhn checksum** — an

invalid number (random digits) will not match by design. Use a documented test PAN (`4111 1111 1111 1111`, `4242 4242 4242 4242`).

- **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (and

longer for some locations)** to take effect. Wait before concluding it's broken.

- Confirm the **location scope** includes where you're testing, and that the test identity isn't in an

exclusion (e.g. the sanctioned in-CDE application you scoped out).

High-confidence matching seems to miss some card numbers.

- The built-in SIT raises confidence when **supporting keywords** (card-brand names, "credit card", etc.)

are near the number. A bare PAN with no context matches at **lower** confidence — if your rule requires High, add a medium-confidence tier or a keyword-independent variant for the "bare PAN in a file" case.

Matches appear in simulation but nothing is blocked.

- That is **correct** — simulation logs what *would* happen without enforcing. To block, move the policy to

enforce for the pilot ring (Implementation Phase 4). If you expected blocking, you're still in simulation.

Endpoint DLP

The Devices/Endpoint location isn't available when creating a policy.

- **Licensing:** Endpoint DLP requires the appropriate plan (E5 / E5 Compliance) — run

`PURVPCI-EndpointReadiness.ps1` for the licensing signal and **verify in the admin center**.

- **Onboarding:** the Devices location depends on **onboarded devices** — confirm in **Purview portal →

Settings → Device onboarding**. No onboarded devices → the location does nothing even if selectable.

Endpoint policy is enforced but device activities (USB/print/upload) aren't caught.

- Confirm the specific **device is onboarded and reporting** (portal device list), meets the **minimum OS

build**, and — for some activities — that the required agent/AV prerequisites per Microsoft docs are met.

- Confirm the **activity is in scope** of the rule (e.g. "copy to USB" is enabled) and that the app/browser

or network path isn't on an **allowed/exception** list.

- Allow for **reporting latency** — endpoint events can take time to surface in Activity Explorer.

False positives (the adoption killer)

Users get policy tips on legitimate content — the number is an internal reference/order number, not a card.

• This is the classic PAN false positive: the Credit Card SIT fires on any **Luhn-valid 13–19 digit**

sequence. Export matches with `PURVPCI-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver.

• **Raise confidence** so only keyword-supported (High) matches fire, and/or **raise instance count** so a

single stray number doesn't trigger.

• For internal identifiers that keep over-matching, move that PAN check to **Exact Data Match**

(`Cardholder PAN – EDM – PCI`) so only your *real* card numbers match — internal reference numbers won't.

• Add a targeted **exception** where justified (the sanctioned in-CDE payment mailbox/site) — narrowly,

with a documented reason.

• Re-simulate after each change and re-measure — don't stack multiple changes blind.

A truncated/masked card number is being flagged.

• A properly **truncated** PAN (first-six/last-four per PCI display rules) is not a full PAN and should not

match a full-PAN detector — if it does, your content likely contains **more than the allowed digits**. Confirm what's actually in the content before treating it as a false positive.

Alerts / incident handling

PAN matches occur but no alert appears / no one is notified.

• Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss

prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.

• Confirm **audit logging is enabled** in the tenant — the report script and Activity Explorer rely on it.

• Confirm the **triage owner/queue** (`PCI DLP Alerts – Triage – Operations`) exists and, if forwarding to

SIEM/Sentinel, that the connector is healthy (Req 2.7).

The report script returns no matches.

• **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run.

• Freshly created policies need **dwell time** — there may simply be no card-data matches yet.

• Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

• Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable** admin.

• Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data

Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

• The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. If a change

landed, it was committed intentionally — the config helper never leaves a policy in **enforce**, so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
PAN policy matches nothing	Mode (disabled/sim), instance count/confidence, Luhn-valid test PAN, propagation time, scope/exclusion
High-confidence misses bare PANs	Bare PAN matches at lower confidence — add a keyword-independent/medium tier
Nothing blocked	Still in **simulation** — that's expected; enforce the ring to block
Devices location missing	Licensing (E5/E5 Compliance) + device **onboarding**
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed-app/network exceptions
FP on internal reference numbers	Raise confidence/instance count, move to **EDM**, add exceptions, re-simulate
Truncated PAN flagged	Confirm content isn't carrying more than first-six/last-four
No alert on match	Alert config on rule, audit logging on, triage owner, SIEM connector
Report returns nothing	Audit latency/dwell time, audit logging on, role
Cmdlet/connect fails	Module updated, modern auth, correct DLP role

7. Best Practices — PCI-DSS DLP Pack (Microsoft Purview)

Field-tested practices for running cardholder-data DLP across endpoint, cloud, and email so the control stays trusted, effective, and low-noise. These complement the Implementation and Testing guides.

Simulate before you enforce — always

• **Never** switch a new or materially changed PAN DLP policy straight to enforce. Run it in

simulation first, long enough to capture representative card-data traffic (Req 2.6), and read the results before enabling.

- Use **simulation with policy tips** on the pilot ring when you want end-user feedback before hard block.
- Treat **simulation mode as your permanent safety switch**: any enforced policy can be returned to

simulation in one setting, instantly removing enforcement with no data change — this is your rollback.

Anchor on PAN, and tune for a low false-positive rate

- Detection anchors on the built-in **Credit Card Number** SIT (card-brand pattern + **Luhn** + keywords).

A lone Luhn-valid number is noise; the same number **with a card-brand keyword nearby** or **ten in one file** is a real signal — use confidence and instance count accordingly.

- Keep **two policy shapes**: a **single-PAN** policy for the "one card number in an email" case, and a

bulk (≥N) policy for exports/spreadsheets — different thresholds, different actions.

- Use **Exact Data Match** (`Cardholder PAN – EDM – PCI`) for storage where the pattern SIT over-fires on

internal reference numbers — it matches your *actual* PANs and drives false positives toward zero, at the cost of an upload + refresh cadence.

- Every false positive that reaches a user erodes trust in **every** policy tip. Budget for a tuning cycle,

not a one-time build.

Respect the card-data rules (don't over- or under-reach)

- **Truncated PANs are not full PANs.** First-six/last-four (per PCI display rules) should *not* match a

full-PAN detector — validate this (Test A6) so masked receipts and logs don't generate noise.

- **SAD detection is best-effort.** CVV/track/PIN detectors are weak alone; use PAN + supporting keywords

as an early-warning signal and treat SAD hits as *investigate*, not proof. Never store SAD — DLP is a backstop, not the control that keeps it out of storage.

- **Never test with real PANs.** Use the documented test card numbers; a test PAN exercises the detector

without you handling live cardholder data.

Right-size the user experience

- Show **clear, actionable policy tips** in business language — tell the user this looks like a payment

card number and what the approved process is, not a compliance error code. Reuse one standard notice (`PCI DLP Notice – Standard – AllPolicies`).

- Prefer **allow-with-justification / override** over hard block where legitimate card-handling exceptions

exist, then **review the overrides** — routine overriding means the policy is mis-scoped (often the sanctioned in-CDE application should be an exception).

• Reserve **hard block/encrypt** for the flows where PCI/compliance require it; escalate to block one flow/location at a time, re-validating each.

Endpoint DLP specifics

• **Onboarding is the gate.** A Devices policy is inert until the device is onboarded (shared with Defender for Endpoint) and reporting — verify onboarding before blaming the policy.

• Roll endpoint controls out **audit-first**: audit USB/print/cloud-upload of PAN-bearing files before restricting, so you see real usage and avoid blocking legitimate workflows.

• Mind **unallowed vs allowed apps/browsers and network exceptions** — configure the allowed-app and network-path lists so sanctioned payment tools aren't caught alongside exfiltration paths.

Scoping and CDE hygiene

• **Use DLP to find PAN sprawl.** The highest early value is discovering PAN *outside* the CDE (email, files, chat, endpoints) — that finding informs scope reduction; the CDE/scope determination stays with compliance/QSA.

• **Exclude the sanctioned in-CDE path deliberately and document it** — don't let the payment application's own mailbox/site flood the queue; scope it out with a written reason.

• **Version and document** any EDM schema (fields, refresh cadence, owner) so tuning changes are traceable for the assessor.

• **Refresh EDM data** on a schedule — stale EDM data silently degrades PAN matching.

Operations & governance

• Give PAN **alerts an owner and an SLA** (Req 2.7), aligned to your incident-response plan. A card-data match volume with no triage is not a control. Forward to SIEM/Sentinel where central SecOps needs visibility.

• Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as data and behavior drift.

• Enforce **least-privilege roles** and, where possible, **separate policy authors from alert triagers** — role separation is expected in a PCI environment.

• Keep a **change log** of every simulate→enforce transition and every action escalation, with the

compliance sign-off attached — this is assessor evidence.

Stay inside the boundary

• DLP is **one control**, not proof the CDE is contained — it inspects content it can classify; combine with sensitivity labels, encryption, and access controls where the risk warrants.

• **Verify licensing/tenant** before relying on any endpoint, EDM, or advanced-classifier capability — plans and portal paths evolve; don't assume a feature is present.

• The **CDE scope, the enforced action per flow, the acceptable false-positive threshold, and PCI-DSS compliance/attestation are compliance/PCI/QSA determinations** — you provide the technical control and the evidence; they own the decision and the attestation.

8. Deliverables Summary — PCI-DSS DLP Pack (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The card-data DLP model — the PAN detector (built-in Credit Card Number SIT + optional EDM), the five locations (email, SharePoint, OneDrive, Teams, endpoint), policy tips/overrides, and the simulate→enforce journey; naming convention.
Requirements Guide	Solution-specific prerequisites (DLP/Endpoint/EDM licensing, DLP roles, device onboarding, card-data classification intent, EDM source PAN table, pilot ring, PAN alert triage owner) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → confirm the PAN detector → build policies **in simulation** → tune false positives → enforce to a pilot ring → expand; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — PAN leaks blocked (A), low false-positive rate (B), incidents handled (C) — plus simulation-first and rollback checks, all with **fake test PANs**.
Troubleshooting Guide	The common failure modes (policy not matching, endpoint location missing, PAN false positives on internal reference numbers, no alerts) and how to resolve them.

Document	What it gives you
Best Practices	Simulate-first discipline, PAN-focused false-positive tuning, truncated-PAN/SAD handling, user-experience design, endpoint specifics, CDE-scoping hygiene, and operations/governance.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**PURVPCI-Discovery.ps1**	Card-data DLP posture + PAN-detector coverage assessment: existing policies and their mode, the built-in Credit Card Number SIT and any EDM schemas, licensing/endpoint readiness signals.	Read-only
2	**PURVPCI-Config.ps1**	PAN DLP policy configuration helper: creates/updates a policy **in simulation mode** for the Credit Card Number SIT and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)
3	**PURVPCI-EndpointReadiness.ps1**	Endpoint-DLP onboarding/readiness checker: onboarded-device count/state and whether the Devices location is usable for card-data endpoint policies.	Read-only

#	Script	Role	Default safety
4	**PURVPCI-Report.ps1**	PAN match / false-positive tuning report: exports simulation/enforcement matches for TP-vs-FP classification and rate calculation.	Read-only
5	**PURVPCI-Set-Scope.ps1**	Scope/config helper: reports and (with `-Commit`) adjusts a policy's included/excluded users/groups (e.g. the pilot ring).	`-WhatIf` (writes need `-Commit`)

Definition of done

• The built-in **Credit Card Number** SIT confirmed as the PAN detector (EDM added only where near-zero

false positives on your real PANs are required).

• Email, cloud (SPO/OneDrive/Teams), and endpoint PAN DLP policies built and **proven in simulation**.

• False-positive rate measured and tuned to at/under the agreed threshold (Gate B), with truncated PANs

and internal reference numbers correctly not matched.

• Enforcement live for the pilot ring with policy tips + override, then expanded per compliance's action

determination (Gate A).

• PAN alerts raised, triaged to disposition per the incident-response plan, and evidence trailed in

Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified; change log and compliance sign-offs captured

as assessor evidence.

> ***Boundary:*** *the solution delivers the technical control and the evidence. The* ***CDE boundary and PCI scope, which card-data flows are in scope, the enforced action per flow, the acceptable false-positive threshold, and PCI-DSS compliance/attestation*** *are compliance/PCI/QSA determinations, captured alongside the delivered evidence. This solution does not attest to PCI-DSS compliance.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PURVPCI-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule for the "Credit Card Number" PAN SIT, plus any EDM PAN SIT you name) in SIMULATION mode, or updates an existing policy's rule, across the chosen locations (Exchange / SharePoint / OneDrive / Teams / Endpoint). Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement is a deliberate, separate portal/change-control step. HOW TO RUN Preview a single-PAN email simulation policy (one card number in an email is the concern): powershell -File .\PURVPCI-Config.ps1 -PolicyName 'DLP - Email PAN - Simulation' `-Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -WhatIf Preview a bulk-export cloud policy (>=10 PANs in a file): powershell -File .\PURVPCI-Config.ps1 -PolicyName 'DLP - SPO+OneDrive+Teams PAN - Simulation'` -Locations SharePoint,OneDrive,Teams -SensitiveTypes 'Credit Card Number' -MinCount 10 -WhatIf Actually create it (still simulation mode): powershell -File .\PURVPCI-Config.ps1 -PolicyName 'DLP - Email PAN - Simulation' ` -Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with PURVPCI-Discovery.ps1. .NOTES Purview — PCI-DSS DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Anchor on the built-in PAN detector; add your EDM PAN SIT name (e.g. 'Cardholder PAN - EDM - PCI') where used. [string[]]$SensitiveTypes = @('Credit Card Number'), 1 = a lone PAN (email case); 10 = a bulk export (spreadsheet case). Keep both policy shapes. [int]$MinCount = 1, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview a single-PAN email simulation policy (one card number in an email is the concern): powershell -File .\PURVPCI-Config.ps1 -PolicyName 'DLP - Email PAN - Simulation' `-Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -WhatIf Preview a bulk-export cloud policy (>=10 PANs in a file): powershell -File .\PURVPCI-Config.ps1 -PolicyName 'DLP - SPO+OneDrive+Teams PAN - Simulation'` -Locations SharePoint,OneDrive,Teams -SensitiveTypes 'Credit Card Number' -MinCount 10 -WhatIf Actually create it (still simulation mode): powershell -File .\PURVPCI-Config.ps1 -PolicyName 'DLP - Email PAN - Simulation' ` -Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with PURVPCI-Discovery.ps1. .NOTES Purview — PCI-DSS DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in

code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Anchor on the built-in PAN detector; add your EDM PAN SIT name (e.g. 'Cardholder PAN - EDM - PCI') where used. [string[]]$SensitiveTypes = @('Credit Card Number'), 1 = a lone PAN (email case); 10 = a bulk export (spreadsheet case). Keep both policy shapes. [int]$MinCount = 1, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

PURVPCI-Discovery.ps1

Purpose: Builds the card-data DLP baseline: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and the locations it covers, confirms the built-in "Credit Card Number" sensitive information type (the Luhn-validated PAN detector) is present, and lists any EDM schemas available for near-zero-false-positive PAN matching. Read-only — makes no changes. Run it before you build simulation policies to see what already exists. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVPCI-Discovery.ps1 -CsvPath .\PURVPCI-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations), confirmation the "Credit Card Number" SIT exists, and EDM schema count, plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review, and the Credit Card Number SIT is present. .NOTES Purview — PCI-DSS DLP Pack. Read-only against Security & Compliance PowerShell. No credentials in code. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVPCI-Discovery.ps1 -CsvPath .\PURVPCI-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations), confirmation the "Credit Card Number" SIT exists, and EDM schema count, plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review, and the Credit Card Number SIT is present. .NOTES Purview — PCI-DSS DLP Pack. Read-only against Security & Compliance PowerShell. No credentials in code. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

PURVPCI-EndpointReadiness.ps1

Purpose: Checks whether Endpoint DLP can actually function before you scope a Devices-location PAN policy: (1) licensing signals for Endpoint DLP (E5 / E5 Compliance service plans) from Microsoft Graph, (2) whether any existing DLP policy uses the Endpoint (Devices) location, and (3) an environmental device-count signal (MDM/Intune-enrolled devices via Graph) as context. Read-only. NOTE: authoritative Purview device-onboarding state is viewed in the Purview portal (Settings > Device onboarding); enrolled-device counts here are context, not proof of onboarding. Endpoints are a primary card-data exfiltration path (a spreadsheet of PANs to a USB stick), so the Devices location matters for PCI DLP — but it is inert until devices are onboarded. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVPCI-EndpointReadiness.ps1 Requires Microsoft Graph PowerShell (Organization.Read.All; DeviceManagementManagedDevices.Read.All for the device-count signal) and Security & Compliance PowerShell (Connect-IPPSSession) for the policy-location check. EXPECTED RESULTS A readiness summary. PASS signal: an Endpoint-DLP-capable plan is present AND devices are onboarded per the

portal. FAIL/verify signal: no capable plan, or the Devices location is unavailable — resolve licensing/onboarding (Req 2.1/2.3) before building endpoint PAN policies. .NOTES Purview — PCI-DSS DLP Pack (Endpoint). Read-only. Verify final onboarding state in the Purview portal. > [CmdletBinding()] param([string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVPCI-EndpointReadiness.ps1 Requires Microsoft Graph PowerShell (Organization.Read.All; DeviceManagementManagedDevices.Read.All for the device-count signal) and Security & Compliance PowerShell (Connect-IPPSSession) for the policy-location check. EXPECTED RESULTS A readiness summary. PASS signal: an Endpoint-DLP-capable plan is present AND devices are onboarded per the portal. FAIL/verify signal: no capable plan, or the Devices location is unavailable — resolve licensing/onboarding (Req 2.1/2.3) before building endpoint PAN policies. .NOTES Purview — PCI-DSS DLP Pack (Endpoint). Read-only. Verify final onboarding state in the Purview portal. > [CmdletBinding()] param([string]$UserPrincipalName)

PURVPCI-Report.ps1

Purpose: Exports DLP rule matches (Exchange, SharePoint/OneDrive, Teams, and Endpoint) over a time window so you can classify true-positive (real PAN) vs false-positive (e.g. a Luhn-valid internal reference number) and compute the false-positive rate that gates simulation-to-enforcement. Works for policies in simulation AND enforcement — simulation matches are logged the same way. Read-only — queries Search-UnifiedAuditLog only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVPCI-Report.ps1 -Days 14 -CsvPath .\PURVPCI-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with real PANs still detected. .NOTES Purview — PCI-DSS DLP Pack. Read-only reporting from the unified audit log. No changes made. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVPCI-Report.ps1 -Days 14 -CsvPath .\PURVPCI-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with real PANs still detected. .NOTES Purview — PCI-DSS DLP Pack. Read-only reporting from the unified audit log. No changes made. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

PURVPCI-Set-Scope.ps1

Purpose: Reports a PAN DLP policy's current locations and mode, and — only with -Commit — narrows an Exchange/OneDrive/SharePoint/Teams policy to a PILOT RING by setting the location member-of scope (e.g. ExchangeSenderMemberOf / OneDriveSharedByMemberOf), so enforcement can be limited to a ring (e.g. 'PCI DLP Pilot Ring - Stage1') before wider expansion. Safe by default: -WhatIf reports only; writes require -Commit. This helper adjusts SCOPE only — it does NOT flip a policy to enforce (that is a deliberate portal/change-control action). HOW TO RUN Report current scope: powershell -File .\PURVPCI-Set-Scope.ps1 -PolicyName 'DLP - Email PAN - Simulation' -WhatIf Restrict the Exchange policy to the PCI pilot-ring group (still simulation mode): powershell -File .\PURVPCI-Set-Scope.ps1 -PolicyName 'DLP - Email PAN - Simulation' ` -PilotRingGroup 'PCIDLPPilotRing@contoso.com' -Location

Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the current locations/mode and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the member-of scope and re-prints it. PASS: the policy's *MemberOf scope now equals the pilot ring, and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — PCI-DSS DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [string]$UserPrincipalName, [switch]$Commit)

How to run: Report current scope: powershell -File .\PURVPCI-Set-Scope.ps1 -PolicyName 'DLP - Email PAN - Simulation' -WhatIf Restrict the Exchange policy to the PCI pilot-ring group (still simulation mode): powershell -File .\PURVPCI-Set-Scope.ps1 -PolicyName 'DLP - Email PAN - Simulation' ` -PilotRingGroup 'PCIDLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the current locations/mode and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the member-of scope and re-prints it. PASS: the policy's *MemberOf scope now equals the pilot ring, and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — PCI-DSS DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [string]$UserPrincipalName, [switch]$Commit)